

Cyfrin
Security Review: Sample Vault
Date: 2024-09-01
Auditors: Alice, Bob

Executive Summary

This is a synthetic Cyfrin-style audit report used for testing.

Findings

[H-1] Reentrancy in withdraw allows fund theft

Description

The withdraw function in contracts/Vault.sol:42 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Impact

An attacker can withdraw arbitrary amounts of user funds via repeated re-entrant calls.

Proof of Concept

Alice deposits 100 tokens. Alice deploys a malicious token whose transfer hook calls back into withdraw before the balance update in contracts/Vault.sol:55. The re-entry drains the vault.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token call.

Resolution: Fixed in commit 1a2b3c4d5e6f7890abcdef1234567890abcdef12